

WEEK 01

CS464 – Data and Network Security

Hafiz Syed Ahmed Qasim
ahmed.qasim@giki.edu.pk

Key Topics

-  **Security Definitions**
Cyber, Information, Network
-  **CIA Triad**
Confidentiality, Integrity, Availability
-  **Security Challenges**
10 Key Challenges
-  **OSI Architecture**
Services & Mechanisms
-  **Security Attacks**
Passive & Active

Lecture Overview



Definitions & Security Objectives

Cybersecurity, Information Security, Network Security, CIA Triad



Security Threats & Attacks

Passive & Active Attacks, Attack Surfaces, Attack Trees



Security Architecture & Analysis

OSI Security Architecture, Services, Mechanisms, Security Strategy



Learning Objectives

- Understand the fundamental definitions of cybersecurity, information security, and network security
- Master the CIA triad and additional security objectives (authenticity, accountability)
- Identify and differentiate between passive and active security attacks
- Analyze attack surfaces and construct attack trees for threat assessment
- Apply OSI security architecture principles to design security strategies

Definition of Cybersecurity



Core Definition

Cybersecurity is the protection of information that is **stored**, **transmitted**, and **processed** in a networked system of computers, other digital devices, network devices, and transmission lines, including the Internet.



Aspects of Protection

- Confidentiality
- Availability
- Accountability
- Integrity
- Authenticity



Methods of Protection



Organizational Policies

Procedures and guidelines



Encryption

Technical safeguarding



Secure Protocols

Communication standards

Information Security



CORE DEFINITION

Information security refers to the **preservation** of **confidentiality**, **integrity**, and **availability** of information.

Core Properties

Confidentiality

Preserving authorized access restrictions

Integrity

Guarding against improper modification

Availability

Ensuring timely access to information

Additional Properties

- Authenticity
- Accountability
- Nonrepudiation
- Reliability



Physical Information

Information security is also concerned with physical (e.g., paper-based) information, not just digital data.

Network Security



CORE DEFINITION

Network security refers to the **protection of networks and their services** from unauthorized modification, destruction, or disclosure, and the provision of **assurance** that the network performs its critical functions correctly with no harmful side effects.



Protection

- Network services
- Unauthorized access



Defense

- Modification
- Destruction



Assurance

- Correct performance
- No harmful effects



Key Focus Areas

Network security ensures that network infrastructure, protocols, and communication channels remain secure, reliable, and free from malicious interference.

Relationship Between the Three Terms



Cybersecurity encompasses

Information Security (electronic data)



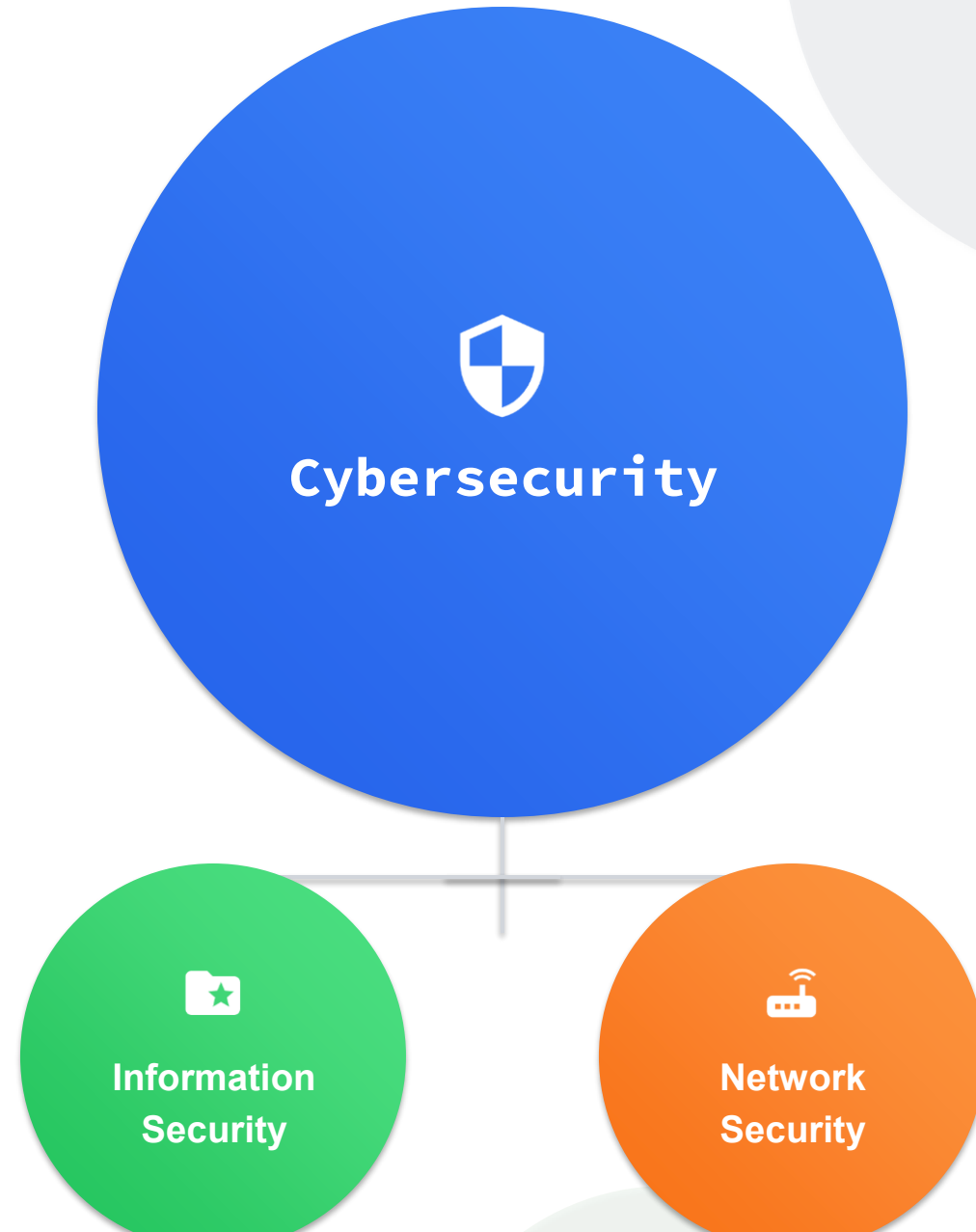
Information Security

Also concerned with physical information (paper-based)



Practical Usage

Terms often used interchangeably in practice



Security Objectives Overview



Confidentiality

- Data confidentiality: Private information not disclosed to unauthorized individuals
- Privacy: Individuals control what information is collected and by whom



Integrity

- Data integrity: Data and programs changed only in authorized manner
- System integrity: System performs intended function correctly



Availability

- Systems work promptly and service not denied to authorized users
- Timely and reliable access to information and services

The CIA Triad



These three concepts form what is often referred to as the **CIA triad** — the fundamental security objectives for both data and information/computing services

Confidentiality



Data Confidentiality

Protection of Sensitive Information



Assures that private or confidential information is not made available or disclosed to **unauthorized individuals**

- Encryption
- Access Controls
- Authentication
- Secure Protocols



Privacy

Individual Information Control



Assures that individuals **control or influence** what information related to them may be collected, stored, and disclosed

Key Aspects: Collection policies, storage limitations, disclosure controls, and consent management

Integrity



Data Integrity

Data & Program Protection

- ✓ Data and programs changed only in **specified and authorized manner**

Key Components:

- **Data Authenticity**
Digital object is indeed what it claims to be
- **Nonrepudiation**
Proof of delivery and sender identity
- **Stored & Transmitted Data**
Protection applies to both storage and transmission



System Integrity

System Performance Assurance

- 🛡️ System performs its **intended function in an unimpaired manner**

Protection Against:

- ⊘ Deliberate unauthorized manipulation of the system
- ⚠️ Inadvertent unauthorized manipulation of the system

- ℹ️ Ensures system operates correctly without unexpected modifications or disruptions

Availability



Assures that systems work **promptly** and service is **not denied** to authorized users



Timely Access

Systems and resources are **accessible when needed**

- ✓ Quick response times
- ✓ Minimal service interruption
- ✓ Efficient resource utilization



Reliable Access

Consistent and dependable information availability

- ✓ System uptime
- ✓ Data consistency
- ✓ Redundancy and backups



Authorized Users

Access granted only to permitted individuals

- ✓ Authentication mechanisms
- ✓ Authorization controls
- ✓ Prevention of denial of service

Authenticity



Definition

Core Concept

Property of being **genuine** and being able to be **verified and trusted**

- Confidence in validity of transmission
- Confidence in validity of message
- Confidence in validity of message originator



Implementation

Verification Process

Verifying that **users are who they say they are**

Each input arriving at the system came from a **trusted source**



Authentication



Digital Signatures



Certificate Authorities



Public Key Infrastructure

Accountability



Core Definition

Tracing Responsibility

Actions of an entity must be traced **uniquely to that entity**



Since truly secure systems are **not yet achievable**, we must be able to trace security breaches to a responsible party



Supported Functions

Key Benefits

- ✓ Nonrepudiation
- ✓ Fault Isolation
- ✓ Intrusion Prevention
- ✓ Legal Action Support
- ✓ Deterrence
- ✓ Intrusion Detection
- ✓ Recovery Actions



Systems must keep **records of activities** for forensic analysis to trace security breaches or aid in transaction disputes

FIPS 199 Security Objectives



NIST Standard FIPS 199

Standards for Security Categorization of Federal Information and Information Systems



Confidentiality

Definition

Preserving authorized restrictions on information access and disclosure

- Protects personal privacy
- Protects proprietary information



Loss of Confidentiality

Unauthorized disclosure of information



Integrity

Definition

Guarding against improper information modification or destruction

- Ensures nonrepudiation
- Ensures authenticity



Loss of Integrity

Unauthorized modification or destruction of information



Availability

Definition

Ensuring timely and reliable access to and use of information

- Timely access
- Reliable access



Loss of Availability

Disruption of access to or use of information or information system

Challenges 1-3

1 Security Not Simple

Seem Straightforward

One-word labels: Confidentiality, Authentication, Nonrepudiation, Integrity

- Requirements appear simple
- Mechanisms are complex
- Understanding involves subtle reasoning



"The mechanisms used to meet those requirements can be quite complex"

2 Potential Attacks

Attack Consideration

Must always consider potential attacks when developing mechanisms

- Successful attacks look at problems differently
- Exploit unexpected weaknesses



"Successful attacks are designed by looking at the problem in a completely different way"

3 Counterintuitive

Procedures Not Obvious

Security mechanisms are complex, not obvious from requirement statements

- Elaborate measures needed
- Make sense when threats considered



"The procedures used to provide particular services are often counterintuitive"

Challenges 4-6

4

Placement Decisions

Where to Implement?

Must decide where to use security mechanisms

- **Physical:** Points in the network
- **Logical:** Layer in architecture (TCP/IP)



"Both in terms of physical placement and in a logical sense"

5

Secret Information

Secret Data Required

Security mechanisms require participants to possess secret information

- Encryption keys
- Creation and distribution challenges
- Protection requirements



"Participants be in possession of some secret information"

6

Battle of Wits

Perpetrator vs Designer

A battle between those finding holes and those closing them

The Asymmetry

- ↘ Attacker: Find **one** weakness
- ↗ Designer: Find and eliminate **all** weaknesses



"Information and network security are essentially a battle of wits"

Challenges 7–8

7

User Perception

Security Investment Challenge

Users and system managers perceive little benefit from security investment until a security failure occurs

- ☹️ Natural tendency to undervalue proactive security
- ⚠️ Benefits often invisible until incident occurs



"Little benefit perceived until security failure occurs"

8

Constant Monitoring

Monitoring Challenge

Security requires regular, even constant, monitoring

- 🕒 Continuous vigilance needed
- ️ Difficult in today's overloaded environment
- 📉 Short-term priorities conflict with long-term security



"Difficult in today's short-term, overloaded environment"

Challenges 9–10

9

Security as Afterthought

Design Process Issue

Security incorporated after design complete rather than integral to design process

 Retroactive security implementation

 Security not built-in from start

 Add-on approach less effective



"Security still too often an afterthought"

10

Impediment to Efficiency

User Experience Challenge

Strong security viewed as impediment to efficient and user-friendly operation

 Perceived barrier to efficiency

 Trade-off with user experience

 Affects both users and administrators



"Strong security as impediment to efficient operation"

Summary of Challenges

- 1 Security not simple as it appears
- 2 Potential attacks on security features
- 3 Procedures are counterintuitive
- 4 Physical and logical placement decisions
- 5 Secret information requirements
- 6 Battle of wits between attackers and designers
- 7 User perception of security investment
- 8 Need for constant monitoring
- 9 Security as afterthought in design
- 10 Security as impediment to efficiency



Key Takeaway

These difficulties will be encountered in numerous ways as we examine various **security threats** and **mechanisms** throughout the course. Understanding these challenges is essential for developing effective security strategies.

The OSI Security Architecture



Systematic Approach



Assess Security Needs

Effectively evaluate security requirements



Evaluate Products & Policies

Choose security solutions systematically



Define Requirements

Characterize approaches effectively



STANDARD

ITU-T X.800

Security Architecture for Open Systems Interconnection (OSI)



International standard



Useful for managers



Vendor product development



Structured Definition

Security services and mechanisms defined systematically for both managers and vendors

Security Architecture Components



Security Attack

Any action that compromises the security of **information** owned by an organization

-  Unauthorized access
-  Information disclosure
-  Disruption of services



Security Mechanism

A process (or device) designed to **detect, prevent, or recover** from a security attack

-  Detection capabilities
-  Prevention measures
-  Recovery procedures



Security Service

Processing/communication service that **enhances security** of data systems and information transfers

-  Counters attacks
-  Uses mechanisms
-  Supports policies

Threat vs Attack



Threat

Any **circumstance or event** with the potential to adversely impact



Organizational operations, assets, reputation



Individuals, other organizations, the Nation



Via information system unauthorized access, destruction, disclosure, modification, denial of service



Attack

Any **malicious activity** that attempts to



Collect



Disrupt



Deny

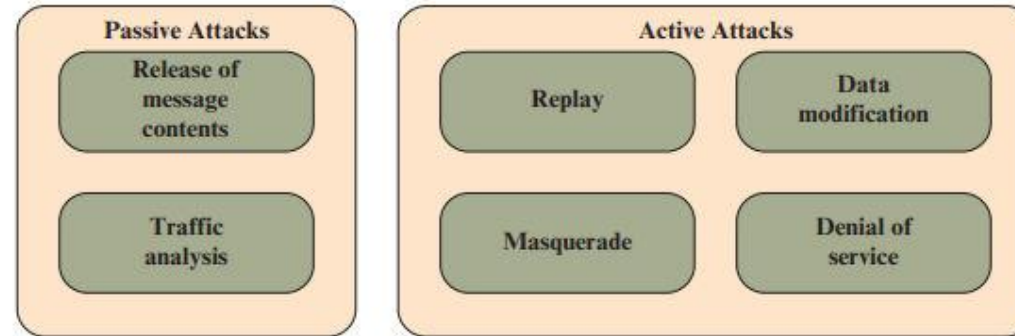


Degrade

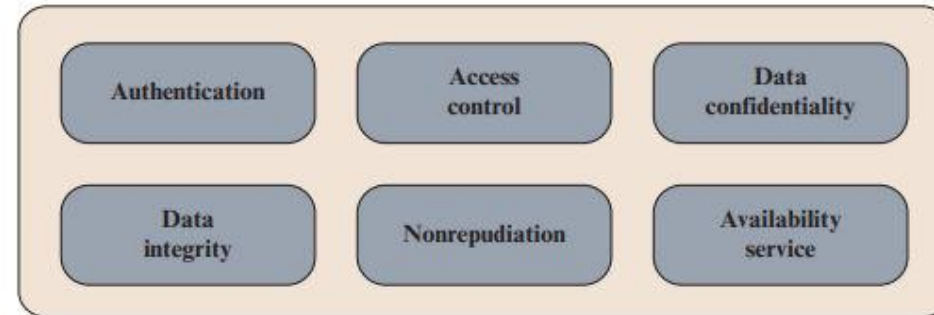


Destroy information system resources or information itself

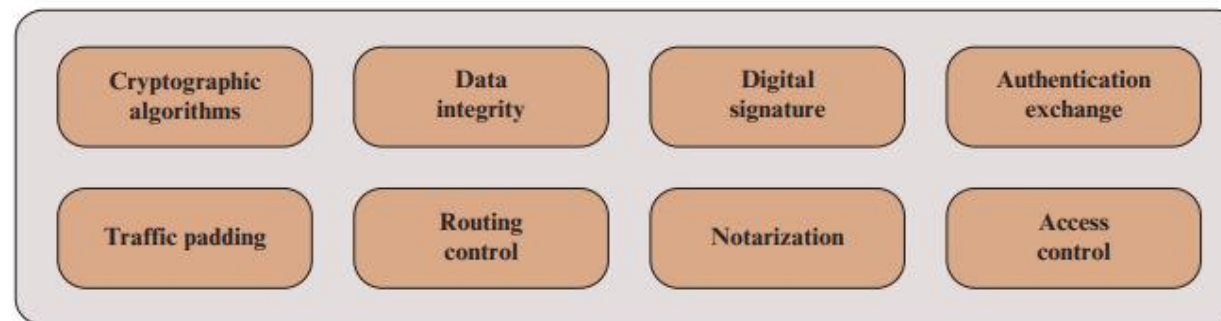
Key Concepts in Security



(a) Attacks



(b) Services



Security Attacks – Overview



Classification in X.800: Passive vs. Active Attacks



Passive Attacks

Attempt to **learn or make use** of information from the system



Does NOT affect system resources



Eavesdropping & traffic monitoring



Active Attacks

Attempt to **alter system resources** or **affect operation**



Modifies data or system state



Causes disruption or unauthorized changes

Passive Attacks – Overview



Definition

Passive attacks are in the nature of **eavesdropping on** or **monitoring of** transmissions. The goal is to **obtain information** that is being transmitted.

1

Release of Message Contents

-  Telephone conversations
-  Electronic mail messages
-  Transferred files

May contain **sensitive or confidential** information

2

Traffic Analysis

-  Observing message patterns
-  Identifying communicating hosts
-  Frequency and length analysis

Even with encryption, **traffic patterns** reveal information

Passive Attacks – Release of Message Contents

 This is **easily understood**. Communications may contain sensitive or confidential information that must be protected.



Telephone Conversations

Voice communications over telephone networks



Electronic Mail

Messages transmitted via email systems



Transferred Files

Documents and files sent over networks



Security Objective

Prevent opponents from learning the contents of these transmissions to protect **confidentiality**

Passive Attacks – Traffic Analysis



This is a **subtler attack**. Even with encryption protecting message contents, **traffic patterns** can reveal valuable information.



Message Patterns

Observe flow and timing of message transmissions



Host Identity & Location

Identify communicating parties and their positions



Frequency & Length

Analyze message size and exchange intervals



Information Disclosure Risk

This observed information can be **useful in guessing the nature** of the communication being performed

Passive Attacks – Detection vs Prevention



Detection

 **Very difficult** to detect

- ✓ No data alteration occurs
- ✓ Message traffic appears normal
- ✓ Sender unaware of third party
- ✓ Receiver unaware of observation

 Neither party aware messages were read



Prevention

 **Feasible to prevent** success of attacks

-  **Encryption** masks message contents
-  Protects sensitive information
-  Ensures confidentiality of communications

 Emphasis on **prevention** rather than detection

Active Attacks – Overview



Active attacks involve **modification of the data stream** or **creation of a false stream**



Replay

Passive capture and subsequent retransmission to produce unauthorized effect



Masquerade

One entity pretends to be a different entity to gain unauthorized access



Data Modification

Alteration, delay, or reordering of portions of legitimate messages



Denial of Service

Prevents or inhibits normal use of communication facilities

Active Attacks – Masquerade



A masquerade takes place when **one entity pretends to be a different entity**



Combines Other Attacks

Usually includes one of the other forms of active attack



Privilege Escalation

Enables low-privilege entity to obtain extra privileges through impersonation



Example Scenario

Authentication sequences can be **captured and replayed** after a valid authentication has taken place. An authorized entity with **few privileges** can obtain **extra privileges** by impersonating an entity that has those privileges.

Active Attacks – Replay



Replay involves the **passive capture** of a data unit and its **subsequent retransmission** to produce an unauthorized effect



Passive Capture

Attacker captures data unit without disturbing normal communication



Store & Wait

Captured data unit is stored for future use by attacker



Retransmit

Data unit is resent to produce unauthorized effect



No Disturbance

Does not disturb normal information flow between client and server



Delayed Effect

Attack can occur at any time after capture

Active Attacks – Data Modification



Some portion of a legitimate message is **altered, delayed, or reordered** to produce an unauthorized effect



Example: Access Request Modification



Original Message

"Allow John Smith to read confidential file accounts"



Modified Message

"Allow Fred Brown to read confidential file accounts"



Man-in-the-Middle

Attacker selectively modifies communicated data between client and server



Direct Access

Modification of data residing on a server or other system after gaining unauthorized access

Active Attacks – Denial of Service



Prevents or inhibits the **normal use or management** of communication facilities



Targeted DoS

Suppress all messages directed to a particular destination



Example: Security audit service



Network-Wide DoS

Disrupt entire network or overload with messages to degrade performance



Disables network or causes congestion



Client/Server Environment



Data Flooding

Overwhelming amount of data sent to server



Resource Exhaustion

Trigger actions consuming substantial computing resources

Passive vs Active Attacks – Comparison



Passive - Detection



Very difficult to detect because no data alteration occurs



Passive - Prevention



Feasible to prevent success using encryption and other security measures



Active - Prevention



Very difficult to prevent absolutely; would require physical protection of all communication facilities and paths at all times



Active - Detection

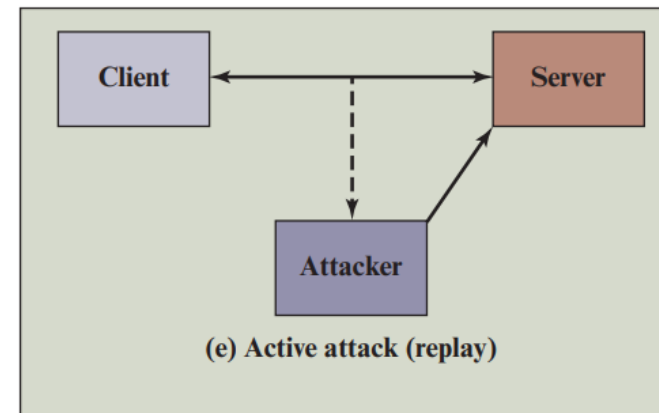
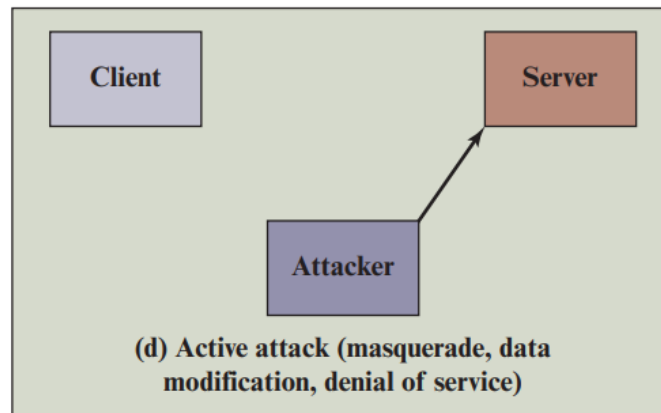
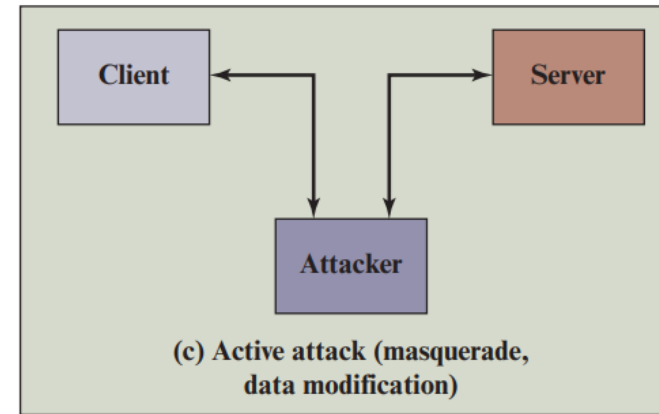
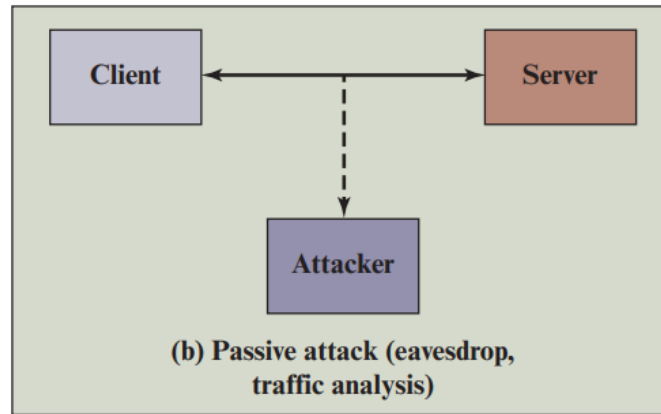
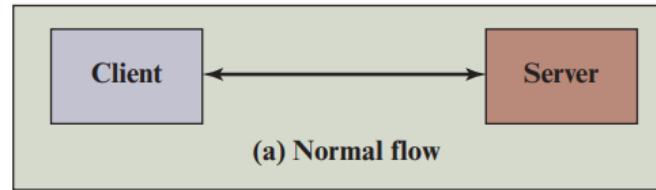


Goal is detection and recovery from disruption or delays; detection has deterrent effect



Active attacks present **opposite characteristics** to passive attacks

Passive vs Active Attacks – Comparison



Attack Surfaces – Definition and Examples



An attack surface consists of the **reachable and exploitable vulnerabilities** in a system



Open Ports

Outward facing Web and other servers, and code listening on those ports



Firewall Services

Services available on the inside of a firewall



Data Processing Code

Code processing incoming data, e-mail, XML, office documents, and industry-specific custom data exchange formats



Interfaces and Forms

Interfaces, SQL, and web forms



Social Engineering Attack

An employee with access to sensitive information vulnerable to social engineering attacks

Attack Surface Categories



Network Attack Surface

Vulnerabilities over:

- ✓ Enterprise network
- ✓ Wide-area network
- ✓ Internet

Examples:

- Denial-of-service attacks
- Communications link disruption
- Intruder attacks



Software Attack Surface

Vulnerabilities in:

- ✓ Application code
- ✓ Utility software
- ✓ Operating system code

Particular Focus:

Web server software



Human Attack Surface

Vulnerabilities created by:

- ✓ Personnel
- ✓ Outsiders

Examples:

- Social engineering
- Human error
- Trusted insiders

Attack Surface Analysis



Attack surface analysis is a **useful technique for assessing** the scale and severity of threats to a system



Awareness

Systematic analysis of points of vulnerability makes developers and security analysts aware of where security mechanisms are required



Surface Reduction

Once defined, designers may find ways to make the surface smaller, making the task of the adversary more difficult



Testing Priorities

Guidance on setting priorities for testing



Security Measures

Guidance on strengthening security measures



Service Modification

Guidance on modifying the service or application

Attack Trees – Definition and Structure



Branching, hierarchical data structure representing potential techniques for **exploiting security vulnerabilities**



Root Node

Goal of the attack



Branches & Subnodes

Ways to reach goal, iteratively represented



Leaf Nodes

Different ways to initiate attack

AND

AND-Node



All subgoals must be achieved

OR

OR-Node



At least one subgoal must be achieved



Branch Attributes

Branches can be labeled with values representing **difficulty**, **cost**, or other attack attributes to enable comparison of alternative attacks

Attack Trees – Motivation and Purpose



Effectively exploit the information available on **attack patterns**



Knowledge Base

CERT and organizations publish security advisories enabling development of body of knowledge about general strategies and specific patterns



Documentation

Security analysts use attack trees to document attacks in structured form that reveals key vulnerabilities



Guidance

Attack trees guide system design, application development, and choice and strength of countermeasures



System & Application Design

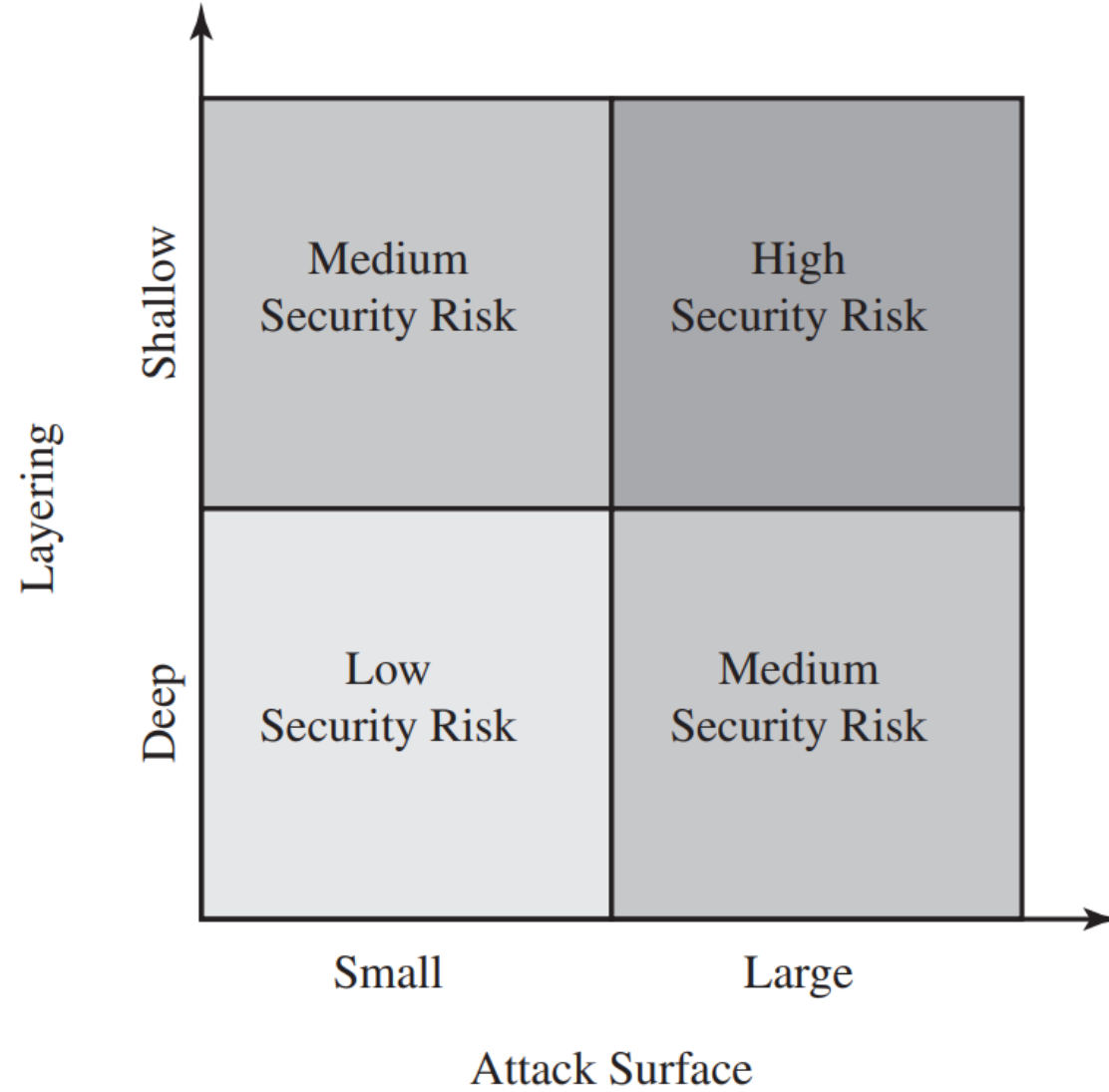
Guide the design of systems and applications to address identified vulnerabilities



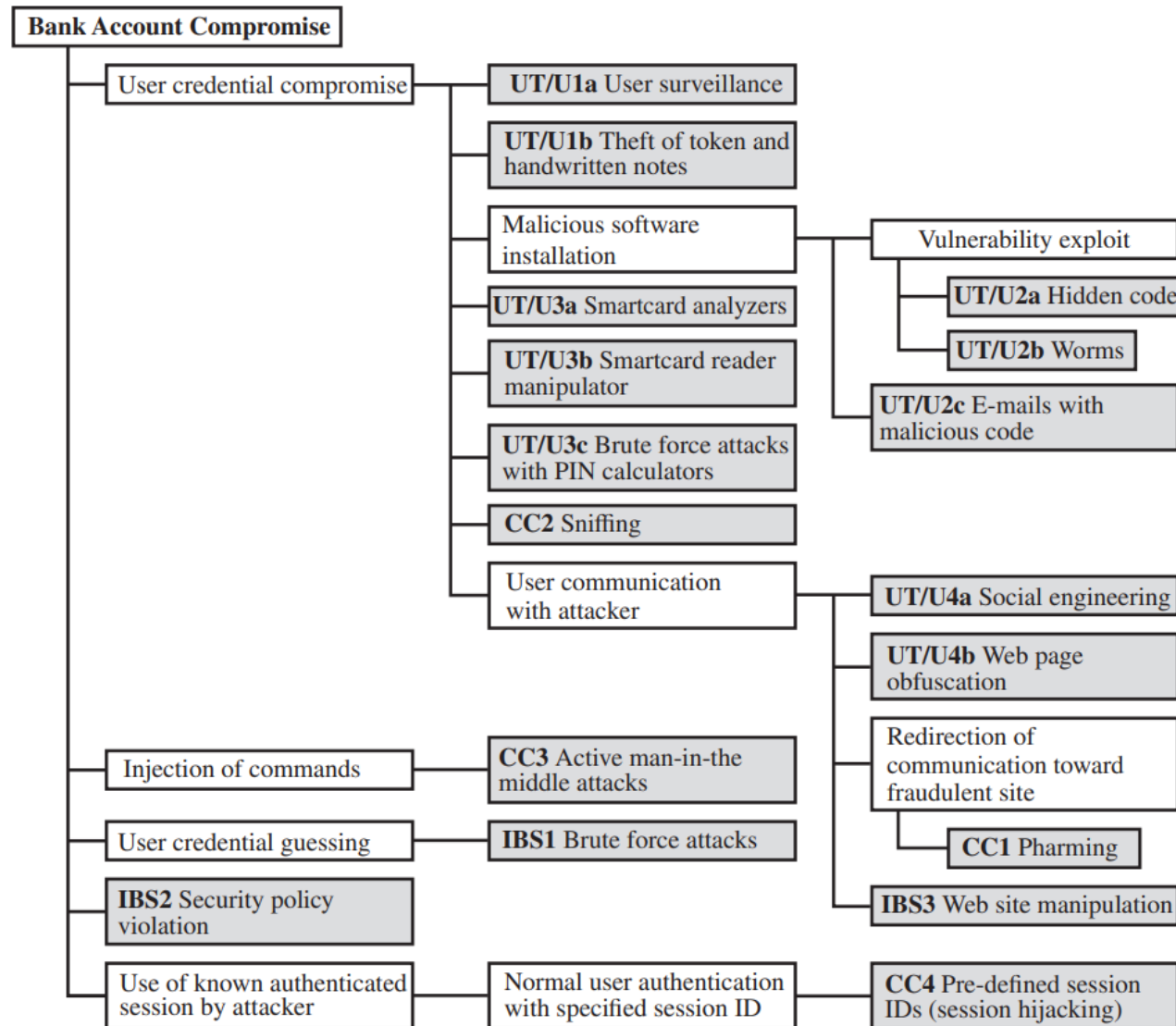
Countermeasures

Inform the choice and strength of security measures to defend against potential attacks

Attack Trees



Attack Trees - Example



Five Attack Strategies

1 User Credential Compromise

Target user equipment, tokens, actions, or malicious software to compromise login/password

2 Injection of Commands

Intercept communication between User Terminal and Internet Banking Service to impersonate valid user

3 User Credential Guessing

Brute force attacks using distributed zombie computers to guess credentials

4 Security Policy Violation

Violate bank's security policy combined with weak access control and logging mechanisms

5 Use of Known Authenticated Session

Force user to connect with preset session ID, then spoof user's identity using known session ID



These five strategies exploit different vulnerabilities across the **authentication components** (User Terminal, Communication Channel, Banking Server)

Computer Security Strategy – Overview



A comprehensive security strategy involves **three critical aspects**



Specification/Policy

WHAT is the security scheme supposed to do?

- ✓ Define security requirements
- ✓ Establish security policies
- ✓ Specify objectives
- ✓ Determine constraints



Implementation/Mechanisms

HOW does it do it?

- ✓ Security mechanisms
- ✓ Cryptographic algorithms
- ✓ Access controls
- ✓ Authentication protocols



Correctness/Assurance

Does it REALLY work?

- ✓ Testing and verification
- ✓ Risk assessment
- ✓ Performance validation
- ✓ Continuous monitoring

Security Policy

⏪ The **first step** in devising security services and mechanisms is to develop a security policy



Concept



Used by computer security professionals



Term used in various ways



Informal description of desired system behavior



Minimum Requirement



An **informal description** of desired system behavior



Defines objectives



Establishes constraints



Guides implementation

Correctness/Assurance



Focuses on the fundamental question: **Does it REALLY work?**



Core Purpose



Ensure security measures are **correctly implemented**



Function as **intended**



Provide intended **protection**



Key Activities

1

Testing security controls

2

Verification of measures

3

Validation of controls

4

Ensure **no vulnerabilities** or weaknesses

Summary of Key Concepts

Foundations

- ✓ Definitions of cybersecurity, information & network security
- ✓ CIA Triad & additional objectives
- ✓ FIPS 199 standards

Threats & Attacks

- ✓ 10 challenges of information security
- ✓ OSI security architecture
- ✓ Passive & active attacks

Defense & Strategy

- ✓ Security services & mechanisms
- ✓ Attack surfaces & trees
- ✓ Computer security strategy



These **difficulties and concepts** will be encountered throughout the course and are essential for developing effective security strategies